



Cloud Security Posture Management

Runbook – Remediation

EC2 Security Group Network Exposure Controls

Control Family	EC2 Security Group Network Exposure Controls
Severity	Medium – High (varies by control)
Audience	Application Teams · Cloud Platform · Cloud Security
Tooling	Wiz Cloud Security Platform
Compliance	CSA CCM v4.0.5 → IVS-06, IVS-07
Version	1.0
Owner	Cloud Security Team
Last Updated	May 2026
Review Cycle	Quarterly

Table of Contents

Table of Contents 1

1. Overview..... 3

2. Controls Covered by This Runbook..... 3

3. Description 4

4. Objective 5

5. Triage Process..... 5

 5.1 Identify Affected Security Groups (Wiz)..... 5

 5.2 Known False Positives – Cargill Default Rules 5

 5.3 Categorize Findings..... 7

 5.4 Exception Logic Quick Reference..... 8

6. Manual Mitigation – AWS Console 8

 6.1 Remove or Restrict an Ingress / Egress Rule..... 8

 6.2 Default Security Group – Remove All Rules (VPC-013) 9

7. Mitigation – AWS CLI..... 9

7.1 Identify Offending Rules	9
7.2 Revoke an Ingress Rule	10
7.3 Revoke an Egress Rule	10
7.4 Default Security Group – Remove All Rules (VPC-013)	10
8. Mitigation Using Terraform (IaC)	11
8.1 Remove or Restrict a Rule	11
8.2 Default Security Group – Enforce No Rules (VPC-013).....	12
8.3 Recommended Terraform Workflow	12
9. Mitigation Using CloudFormation (IaC)	13
9.1 Remove or Restrict a Rule	13
9.2 Default Security Group – Enforce No Rules (VPC-013).....	14
9.3 Recommended CloudFormation Workflow	14
10. Document Exception	15
11. Detective Control	15
12. Validation and Success Criteria.....	16
13. References.....	16

1. Overview

Field	Details
Detection Tool	Wiz Cloud Security Platform
Wiz Rule	Cloud Configuration Rules Wiz
Detective Control	AWS Security Group rule analysis via Wiz
Engineering Reference	Cargill VM Security Groups Guide

2. Controls Covered by This Runbook

All controls below follow the same remediation pattern. Use the Port(s)/Protocol(s) column to identify the specific rule(s) to remove or restrict for each finding.

Control ID	Control Name	Port(s) / Protocol(s)
VPC-013	Default security group should have no rules configured	All (any rule is a violation)
Firewall-007	EC2 Security Group should not allow access to a wide private network	Any port – wide private CIDR (e.g. 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16)
VPC-033	EC2 Security Group should not allow unrestricted access using ICMP	ICMP / All
VPC-034	EC2 Security Group should restrict access to remote administration ports	TCP:22, TCP:3389
VPC-066	EC2 Security Group should restrict ArangoDB access	TCP/UDP:8529
VPC-021	EC2 Security Group should restrict CIFS access	UDP:137, UDP:138, UDP:445, TCP:139, TCP:445
VPC-067	EC2 Security Group should restrict CouchDB access	TCP:5984
VPC-022	EC2 Security Group should restrict DNS access	TCP:53
VPC-023	EC2 Security Group should restrict DNS access	UDP:53
VPC-024	EC2 Security Group should restrict FTP access	TCP:21
VPC-025	EC2 Security Group should restrict FTP Data access	TCP:20
Firewall-005	EC2 Security Group should restrict HTTP access	TCP:80
Firewall-006	EC2 Security Group should restrict HTTPS access	TCP:443
VPC-065	EC2 Security Group should restrict MaxDB access	TCP:7210

Firewall-004	EC2 Security Group should restrict MongoDB access	TCP:27017–27020
VPC-026	EC2 Security Group should restrict mSQL access	TCP/UDP:4333
VPC-030	EC2 Security Group should restrict MSSQL access	TCP:1433
VPC-031	EC2 Security Group should restrict MSSQL access	UDP:1434
VPC-027	EC2 Security Group should restrict MySQL access	TCP:3306
VPC-068	EC2 Security Group should restrict Neo4J access	TCP:7473, TCP:7474, UDP:7473
VPC-028	EC2 Security Group should restrict NetBIOS access	TCP:137, TCP:139, UDP:137, UDP:138
Firewall-003	EC2 Security Group should restrict Oracle DB access	TCP:1521, TCP:1830, TCP:2483, TCP:2484
VPC-029	EC2 Security Group should restrict PostgreSQL access	TCP:5432
VPC-014	EC2 Security Group should restrict RDP access	TCP:3389
VPC-070	EC2 Security Group should restrict RethinkDB access	TCP:28015, TCP:29015, TCP:8080, UDP:28015, UDP:29015
VPC-069	EC2 Security Group should restrict Riak access	TCP:8087, TCP:8098
VPC-019	EC2 Security Group should restrict RPC access	TCP:135
VPC-020	EC2 Security Group should restrict SMB access	TCP:445
VPC-032	EC2 Security Group should restrict SMTP access	TCP:25
VPC-071	EC2 Security Group should restrict Solr access	TCP:7574, TCP:8983
VPC-015	EC2 Security Group should restrict SSH access	TCP:22
VPC-016	EC2 Security Group should restrict Telnet access	TCP:23
VPC-017	EC2 Security Group should restrict VNC Listener access	TCP:5500
VPC-018	EC2 Security Group should restrict VNC Server access	TCP:5800, TCP:5900

3. Description

These controls identify EC2 Security Groups that expose sensitive ports or protocols to overly broad sources — including the internet (0.0.0.0/0), wide private CIDR ranges, or any source beyond what is operationally required.

Overly permissive security group rules are one of the most common causes of cloud security incidents. They expand the network attack surface, enable lateral movement, and may allow direct access to databases, remote administration interfaces, or legacy protocols that should never be internet-facing.

Each control in this family targets a specific port or protocol known to be high-risk when exposed without restriction. The remediation pattern is consistent across all controls: identify the offending rule, determine whether it is a Cargill default rule or a custom rule, and either remove it, restrict its source CIDR, or file a formal exception.

4. Objective

This runbook provides standardized operational guidance for security and cloud operations teams to:

- Validate security group exposure findings in Wiz
- Distinguish Cargill platform default rules from custom rules requiring remediation
- Remove or restrict overly permissive ingress and egress rules
- Apply the Cargill exception framework where a rule has a legitimate business purpose

5. Triage Process

 **General triage principles** — including how to assess whether a finding is valid, a false positive, or an accepted risk — are defined in the [Master Template – Remediation SOP](#). Complete that review before proceeding with the control-specific steps below.

5.1 Identify Affected Security Groups (Wiz)

1. Navigate to Wiz → Cloud Configuration Findings and filter by the relevant Control ID (see Section 2).
2. Export the list of affected Security Groups.
3. For each finding, collect:
 - Security Group ID and name
 - AWS Account ID and region
 - VPC ID
 - The specific rule(s) flagged (protocol, port, source/destination CIDR)
 - Whether the rule is ingress or egress
 - Associated EC2 instances or other resources

5.2 Known False Positives – Cargill Default Rules

 **Check this section before taking any action.** Cargill's platform automatically applies a set of default security group rules to all VMs. These rules may trigger Wiz findings but are

intentional and approved. Do not remove them without confirming they are not platform defaults.

Default Linux VM Rules (auto-applied by platform):

Description	Protocol	Port(s)	Direction	Source / Destination
StrongDM	TCP	22	Ingress	10.6.168.0/24, 10.83.53.0/27, 10.83.53.32/27, 10.83.53.64/27
AWS Service APIs	TCP	443	Egress	Various AWS endpoints
Datadog APIs	TCP	443	Egress	Various Datadog endpoints
Tanium	TCP	17472, 17444, 17475	Egress	10.47.133.117/32, 10.47.133.97/32, 10.47.133.74/32, 167.136.230.226/32
ICMP	ICMP	-1	Ingress	0.0.0.0/0
ICMP	ICMP	-1	Egress	0.0.0.0/0

Default Windows VM Rules (auto-applied by platform):

Description	Protocol	Port(s)	Direction	Source / Destination
StrongDM	TCP	3389	Ingress	10.6.168.0/24, 10.83.53.0/27, 10.83.53.32/27, 10.83.53.64/27
AWS Service APIs	TCP	443	Egress	Various AWS endpoints
Datadog APIs	TCP	443	Egress	Various Datadog endpoints
Microsoft patches	TCP	80, 443	Egress	0.0.0.0/0
WSUS patches	TCP	8530, 8531	Egress	10.48.73.29/32
Tanium	TCP	17472, 17444, 17475	Egress	10.47.133.117/32, 10.47.133.97/32, 10.47.133.74/32, 167.136.230.226/32
Active Directory	TCP	53, 88, 135, 389, 445, 464, 636, 3268, 3269, 49152–65535	Egress	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16
Active Directory	UDP	53, 88, 123, 138, 389, 445, 464, 49152–65535	Egress	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16
ICMP	ICMP	—	Ingress	0.0.0.0/0
ICMP	ICMP	—	Egress	0.0.0.0/0

i If the flagged rule matches a default rule above (same port, protocol, direction, and source/destination CIDR), confirm with the platform team before taking action. These rules are managed by the platform and should not be modified manually.

Controls most likely to surface default-rule false positives:

Control ID	Why It May Be a False Positive
VPC-033	ICMP is allowed by default on all Cargill VMs (ingress + egress from 0.0.0.0/0)
VPC-015	SSH:22 ingress is allowed from StrongDM CIDRs by default on Linux VMs
VPC-034	SSH:22 / RDP:3389 ingress from StrongDM CIDRs is a default — only flag if source is 0.0.0.0/0 or a broad CIDR
VPC-014	RDP:3389 ingress is allowed from StrongDM CIDRs by default on Windows VMs
Firewall-005	HTTP:80 egress to 0.0.0.0/0 is allowed by default on Windows VMs (Microsoft patches)
Firewall-006	HTTPS:443 egress to 0.0.0.0/0 is allowed by default on all VMs
VPC-022 / VPC-023	DNS:53 egress is part of Windows Active Directory default rules
VPC-019	RPC:135 egress is part of Windows Active Directory default rules
VPC-020 / VPC-021	SMB/CIFS:445 egress is part of Windows Active Directory default rules
VPC-028	NetBIOS egress is part of Windows Active Directory default rules
Firewall-007	Wide private CIDR egress rules (10.0.0.0/8 etc.) are part of Windows AD default rules

5.3 Categorize Findings

Once you have confirmed the rule is not a platform default, assign one of the following categories:

Category	Description	Next Action
	Rule has no business purpose; port/protocol should not be exposed to this source.	→ Proceed to Section 6, 7, 8, or 9
	Rule serves a legitimate purpose but the source/destination CIDR is too broad. Narrow to the minimum required.	→ Proceed to Section 6, 7, 8, or 9 with CIDR restriction
	Rule has a documented business need that cannot be resolved through CIDR restriction.	→ Proceed to Section 10 (Exception Process)

Before acting, confirm: resource owner · business purpose of the rule · ingress or egress · associated application or service · whether the source/destination CIDR can be narrowed

5.4 Exception Logic Quick Reference

Use this table to determine whether a security group rule requires a formal exception. For full details see the [Cargill VM Security Groups Engineering Guide](#).

Egress Rules:

Destination	Rule	Exception Required?
Internet (0.0.0.0/0)	Port 80 only	✗ No
Internet (0.0.0.0/0)	Port 443 only	✗ No
Internet (0.0.0.0/0)	Any other single port	☑ Yes
Internet (0.0.0.0/0)	Any port range	☑ Yes
CNET (private RFC-1918)	Any single port except 21 or 23	✗ No
CNET (private RFC-1918)	Port 21 (FTP)	☑ Yes
CNET (private RFC-1918)	Port 23 (Telnet)	☑ Yes
CNET (private RFC-1918)	Port range within 50000–60000	✗ No
CNET (private RFC-1918)	Port range outside or overlapping 50000–60000	☑ Yes

Ingress Rules:

Source	Rule	Exception Required?
Internet (0.0.0.0/0)	Any port or range	☑ Yes — always
Non-internet CIDR	Restricted ports: 20, 21, 22, 23, 69, 110, 3389	☑ Yes
Non-internet CIDR	Any non-restricted single port	✗ No
Non-internet CIDR	Port range including any restricted port	☑ Yes
Non-internet CIDR	Port range of only non-restricted ports	✗ No

6. Manual Mitigation – AWS Console

Use this approach for one-off remediations or when the security group is not managed by IaC.

6.1 Remove or Restrict an Ingress / Egress Rule

☑ **Removing or restricting a rule is safe and immediately effective.** If the rule is needed, add a replacement with a narrower CIDR before removing the broad rule to avoid service disruption.

1. Navigate to AWS Console → VPC → Security Groups.
2. Search for and select the Security Group identified in Wiz.
3. Review the Inbound rules or Outbound rules tab and locate the flagged rule.
4. To remove the rule: select it → click Delete → confirm.
5. To restrict the rule (narrow the CIDR):
 - Click Edit inbound rules or Edit outbound rules
 - Update the source/destination CIDR to the minimum required range
 - Click Save rules

Result: The overly permissive rule is removed or restricted. Wiz will re-evaluate on its next scan cycle.

 For production security groups: notify the resource owner and confirm no active traffic depends on the rule before removing it. Consider restricting the CIDR first and monitoring before full removal.

6.2 Default Security Group – Remove All Rules (VPC-013)

The default security group in every VPC must have no inbound or outbound rules. No resources should use the default security group.

1. Navigate to AWS Console → VPC → Security Groups.
2. Filter for the security group named default in the affected VPC.
3. Select the security group → Inbound rules tab → Edit inbound rules → delete all rules → Save rules.
4. Select the security group → Outbound rules tab → Edit outbound rules → delete all rules → Save rules.
5. Confirm no EC2 instances or other resources are using the default security group. If they are, move them to a dedicated security group before removing rules.

7. Mitigation – AWS CLI

Run the following commands for the affected security group. Ensure you have the necessary VPC/EC2 permissions before proceeding.

7.1 Identify Offending Rules

```
aws ec2 describe-security-groups \
  --group-ids <SECURITY_GROUP_ID> \
  --query "SecurityGroups[*].{Ingress:IpPermissions,Egress:IpPermissionsEgress}" \
  --output json
```

7.2 Revoke an Ingress Rule

Example: revoke SSH (TCP:22) from 0.0.0.0/0. Replace values to match the flagged rule.

```
aws ec2 revoke-security-group-ingress \
  --group-id <SECURITY_GROUP_ID> \
  --protocol tcp \
  --port 22 \
  --cidr 0.0.0.0/0
```

i Replace --protocol, --port, and --cidr with the values matching the flagged rule. For UDP use --protocol udp. For ICMP use --protocol icmp --port -1.

7.3 Revoke an Egress Rule

Example: revoke MySQL (TCP:3306) egress to 0.0.0.0/0.

```
aws ec2 revoke-security-group-egress \
  --group-id <SECURITY_GROUP_ID> \
  --protocol tcp \
  --port 3306 \
  --cidr 0.0.0.0/0
```

7.4 Default Security Group – Remove All Rules (VPC-013)

```
# Get all ingress rules then revoke them
INGRESS=$(aws ec2 describe-security-groups \
  --group-ids <SECURITY_GROUP_ID> \
  --query "SecurityGroups[0].IpPermissions" \
  --output json)

aws ec2 revoke-security-group-ingress \
  --group-id <SECURITY_GROUP_ID> \
  --ip-permissions "$INGRESS"

# Get all egress rules then revoke them
EGRESS=$(aws ec2 describe-security-groups \
```

```
--group-ids <SECURITY_GROUP_ID> \
--query "SecurityGroups[0].IpPermissionsEgress" \
--output json)

aws ec2 revoke-security-group-egress \
  --group-id <SECURITY_GROUP_ID> \
  --ip-permissions "$EGRESS"
```

⚠ Verify the security group ID is the default SG for the VPC before running. Check that no resources are attached first: `aws ec2 describe-network-interfaces --filters Name=group-id,Values=<SECURITY_GROUP_ID>`

8. Mitigation Using Terraform (IaC)

Use this approach when security groups are managed as Infrastructure as Code.

Importing manually created security groups: If the security group was not originally provisioned via Terraform, import it into state before proceeding:

```
terraform import aws_security_group.this <SECURITY_GROUP_ID>
```

8.1 Remove or Restrict a Rule

Remove the offending rule from the ingress or egress block, or narrow its CIDR:

```
resource "aws_security_group" "example" {
  name     = "example-sg"
  vpc_id = var.vpc_id

  # BEFORE (flagged - SSH open to the world):
  # ingress {
  #   from_port = 22
  #   to_port   = 22
  #   protocol  = "tcp"
  #   cidr_blocks = ["0.0.0.0/0"]
  # }
```

```
# AFTER (restricted to StrongDM CIDRs only):
ingress {
  from_port    = 22
  to_port      = 22
  protocol     = "tcp"
  cidr_blocks = [
    "10.6.168.0/24",
    "10.83.53.0/27",
    "10.83.53.32/27",
    "10.83.53.64/27"
  ]
  description = "SSH via StrongDM only"
}
}
```

i For database ports (MySQL, MSSQL, PostgreSQL, MongoDB, Oracle, etc.), restrict the source CIDR to the specific application subnet(s) that require access — never to 0.0.0.0/0 or broad private ranges.

8.2 Default Security Group – Enforce No Rules (VPC-013)

Use the `aws_default_security_group` resource to enforce an empty default security group:

```
resource "aws_default_security_group" "default" {
  vpc_id = aws_vpc.main.id

  # Omitting ingress and egress blocks enforces zero rules
  tags = {
    Name = "default-sg-no-rules"
  }
}
```

i The `aws_default_security_group` resource adopts the existing default SG rather than creating a new one. Omitting ingress and egress blocks enforces zero rules.

8.3 Recommended Terraform Workflow

1. Wiz identifies the overly permissive security group rule.
2. Security team validates the finding is not a platform default (Section 5.2).

3. If the security group is not in Terraform state, run terraform import.
4. Update the Terraform resource to remove or restrict the offending rule.
5. Run terraform plan — review the proposed changes carefully.
6. Obtain peer review / approval of the plan output.
7. Run terraform apply to enforce the change.

9. Mitigation Using CloudFormation (IaC)

Use this approach when security groups are managed via CloudFormation.

Drift detection: If rules were modified manually outside of CloudFormation, run a drift detection check before executing a change set.

AWS Console → CloudFormation → Stack → Stack actions → Detect stack drift

9.1 Remove or Restrict a Rule

Remove or narrow the offending rule in the SecurityGroupIngress or SecurityGroupEgress properties:

```
Resources:
  ExampleSecurityGroup:
    Type: AWS::EC2::SecurityGroup
    Properties:
      GroupDescription: Example security group
      VpcId: !Ref VPC

  # BEFORE (flagged - RDP open to 0.0.0.0/0):
  # SecurityGroupIngress:
  #   - IpProtocol: tcp
  #     FromPort: 3389
  #     ToPort: 3389
  #     CidrIp: 0.0.0.0/0

  # AFTER (restricted to StrongDM CIDRs):
  SecurityGroupIngress:
    - IpProtocol: tcp
      FromPort: 3389
      ToPort: 3389
      CidrIp: 10.6.168.0/24
      Description: RDP via StrongDM only
    - IpProtocol: tcp
      FromPort: 3389
```

```
ToPort: 3389
CidrIp: 10.83.53.0/27
Description: RDP via StrongDM only
```

i CloudFormation requires one CidrIp per rule entry. For multiple CIDRs, add multiple rule entries with the same port and protocol.

9.2 Default Security Group – Enforce No Rules (VPC-013)

CloudFormation does not have a native resource for adopting and emptying the default security group. The recommended approach is:

1. Ensure no resources reference the default security group — use dedicated SGs for all resources.
2. Use a Custom Resource (Lambda-backed) or an AWS Config Remediation to automatically remove rules from the default SG.
3. As an interim measure, remove all rules manually via Console or CLI (Sections 6.2 / 7.4) and enforce the policy via the AWS Config managed rule vpc-default-security-group-closed.

```
# AWS Config rule to enforce default SG has no rules
Resources:
  DefaultSGClosedConfigRule:
    Type: AWS::Config::ConfigRule
    Properties:
      ConfigRuleName: vpc-default-security-group-closed
      Source:
        Owner: AWS
        SourceIdentifier: VPC_DEFAULT_SECURITY_GROUP_CLOSED
```

9.3 Recommended CloudFormation Workflow

1. Run drift detection on the stack before making any changes.
2. Security team validates the finding is not a platform default (Section 5.2).
3. Update CloudFormation template to remove or restrict the offending rule.
4. Create a change set and review the proposed changes carefully.
5. Obtain peer review / approval of the change set.
6. Execute the stack update to enforce remediation.

10. Document Exception

Use the exception process when a security group rule has a valid, documented business reason that cannot be resolved through CIDR restriction (Category C findings from Section 5.3).

Exception Process: Submit and manage exceptions using the formal exception governance process. All required fields, approval workflows, and expiration timelines are defined there.

→ [Wiz CSPM Exception Governance](#)

Also consult the [Cargill VM Security Groups Engineering Guide](#) to confirm whether the rule requires a formal exception or is allowed without one under platform policy.

At minimum, every exception must include:

- Business justification for the permissive rule
- Approver name and approval date
- Exception expiration date (maximum 180 days — must be reviewed and renewed)
- Compensating controls in place (e.g. host-based firewall, IDS/IPS monitoring, traffic logging enabled)
- Specific port(s), protocol(s), and source/destination CIDR(s) covered by the exception

11. Detective Control

Wiz continuously evaluates EC2 Security Group rules against the controls defined in Section 2, flagging any rule where the source or destination CIDR is broader than permitted for the given port and protocol.

Unlike IAM controls, security group findings are near-real-time — Wiz re-evaluates rules on each scan cycle (typically within hours of a rule change). Engineers can also verify findings independently using the AWS Console or CLI.

To verify a finding independently:

```
aws ec2 describe-security-groups \
  --filters Name=vpc-id,Values=<VPC_ID> \
  --query
"SecurityGroups[*].{ID:GroupId,Name:GroupName,Ingress:IpPermissions,Egress:IpPermissionsEgress}"
\
  --output table
```

To check which resources are attached to a security group:

```
aws ec2 describe-network-interfaces \
  --filters Name=group-id,Values=<SECURITY_GROUP_ID> \
  --query
"NetworkInterfaces[*].{ID:NetworkInterfaceId, Instance:Attachment.InstanceId, Description:Description}
\
  --output table
```

12. Validation and Success Criteria

After completing remediation, verify success using the following checklist before closing the finding.

☐	Re-check the specific Security Group in Wiz and confirm the finding status is Resolved or No longer applicable.
☐	Confirm the offending rule has been removed or the source/destination CIDR has been narrowed to the minimum required.
☐	Confirm no service disruption or application alerts were triggered following the rule change.
☐	Confirm no resources remain attached to the default security group (VPC-013 only).
☐	Update the Finding Management Tool with the remediation outcome and date.
☐	If an exception was filed (Category C), confirm it is logged in the exception register with an expiration date.
☐	Update IaC documentation if any environment-specific changes were made.

13. References

- [Wiz Cloud Configuration Findings Documentation](#)
- [Cargill VM Security Groups Engineering Guide](#)
- [AWS EC2 Security Groups Documentation](#)
- [CSA CCM v4.0.5 Cargill Framework \(Wiz\)](#)
- [Cloud Security Navigator \(CSN\)](#)
- [Wiz CSPM Exception Governance](#)
- [Master Template – Remediation SOP](#)
- [CSPM Finding Management Tool](#)

